

Rapport de validation de sécurité

Plateforme de détection intelligente et automatisée des cyberattaques - version 10 durcie

Étudiant	Sadik DASSAA
Projet	Supervision des cyberattaques
Périmètre	Suricata, FastAPI, Streamlit, Docker et authentification
Date de validation	9 août 2026
Verdict	Tests techniques réussis - usage local durci

Conclusion exécutive : la v10 corrige les principaux écarts identifiés dans la v9. Elle ne doit toutefois pas être présentée comme sécurisée à 100 % ni comme prête à être exposée directement sur Internet.

1. Mesures de durcissement réalisées

- CORS restreint au dashboard local, validation de l'hôte et en-têtes HTTP de sécurité.
- Premier compte administrateur, puis fermeture automatique de l'inscription publique.
- Blocage persistant des tentatives de connexion dans SQLite sur une fenêtre de cinq minutes.
- Récupération par code e-mail, changement du mot de passe et révocation des sessions.
- Journal d'audit du compte avec conservation limitée à 90 jours.
- Historiques et statistiques isolés par utilisateur ; refus des accès croisés.
- Destinataire e-mail limité au propriétaire vérifié de l'événement.
- Extensions et tailles des imports contrôlées avant traitement en mémoire.
- Conteneurs non privilégiés, racine en lecture seule, capacités supprimées et ports locaux.
- Variables Gmail limitées à l'API ; le dashboard ne reçoit plus ces secrets.

2. Paramètres de sécurité

Contrôle	Valeur v10
Session authentifiée	12 heures
Code e-mail	6 chiffres, 10 minutes, 5 essais
Renvoi du code	60 secondes minimum
Connexion	5 échecs par identifiant/client sur 5 minutes
Import CSV	200 Mo par défaut, plafond configurable 512 Mo
Import EVE	64 Mo par défaut, plafond configurable 256 Mo
Exposition réseau	127.0.0.1 uniquement

3. Résultats des vérifications

Vérification	Résultat
Compilation Python et analyse AST	Réussi
Authentification et inscription initiale	Réussi
CORS, TrustedHost et en-têtes HTTP	Réussi
Refus des extensions et fichiers surdimensionnés	Réussi
Isolation entre deux utilisateurs	Réussi
Refus de clôture d'un incident appartenant à un autre compte	Réussi
Changement et récupération du mot de passe	Réussi
Blocage persistant et journal d'audit	Réussi
Analyse des dépendances avec pip-audit	Aucune vulnérabilité connue signalée
Structure Compose analysée	Valide

4. Migration et conservation

La base des comptes, l'historique et les journaux Suricata sont conservés. Le premier compte existant devient administrateur principal. Les lignes v9 sans propriétaire lui sont attribuées, puis toutes les nouvelles écritures reçoivent un identifiant utilisateur.

5. Limites et recommandations

Le verdict concerne l'utilisation locale sur le poste Windows déjà validé. Pour une exposition publique, ajouter au minimum HTTPS, un reverse proxy, une gestion centralisée des secrets, des sauvegardes chiffrées, une supervision externe, des mises à jour planifiées et un test d'intrusion indépendant.

Verdict final : plateforme locale durcie et testée. Aucun système ne peut être garanti sécurisé à 100 %.